

Athens, 25-09-2023

Protocol No.: 2398

DECISION 30/2023

The Hellenic Data Protection Authority convened at the invitation of its President in a meeting on 13-06-2023 following the meetings of 15/2/2022 and 12/4/2022, in order to examine the case referred to in the background of this document. Present were the President of the Authority, Konstantinos Menoudakos, the regular members Konstantinos Lamprinoudakis, as rapporteur, Christos Kalloniatis, Aikaterini Iliadou, as well as the alternate members Christos Papadopoulos, Nikolas Libos, and Maria Psalla, replacing the regular members Spyros Vlachopoulos, Charalampos Anthopoulos, and Grigorios Tsolias, who, although duly summoned in writing, did not attend due to impediments. In the meeting, without voting rights, were present, by order of the President, the auditors Fotini Karvela, Konstantinos Limniotis, and Leonidas Roussos, specialists, as assistants to the rapporteur, and Irini Papageorgopoulou, an employee of the Administrative Affairs Department, as secretary.

The Authority took into account the following:

The Authority conducted an extraordinary on-site inspection on 18/11/2019 at the Athens Urban Transport Organization (OASA) S.A. (hereinafter "data controller" or OASA) regarding the protection of personal data processed within the framework of the Automatic Fare Collection System (hereinafter AFC), a system also referred to as "electronic ticketing," in light of what the Authority had outlined in its Opinion No. 4/2017. Specifically, the Authority, in Opinion 4/2017, had expressed its opinion on the processing that OASA would carry out within the framework of the then-upcoming electronic ticketing system. Already in its previous Opinion No. 1/2017, the Authority had set forth all the conditions that must be met for the processing of personal data within an electronic system for movements made using public transport (which data also includes special category data, such as those related to the movements of persons with disabilities) to comply with the requirements of the relevant legal framework and not to infringe upon the fundamental rights and freedoms of individuals. The Authority, in its latest Opinion 4/2017, concluded that the new form of the said processing, as described by OASA, had been satisfactorily harmonized with the conditions set by the Authority in Opinion 1/2017. However, the Authority, in Opinion 4/2017, determined that OASA, as the data controller, should make certain modifications, the effectiveness of which must be substantiated by a data protection impact assessment (hereinafter DPIA) that the data controller is obliged to prepare, which should be documented in a document approved by the management of OASA and made available by 25 May 2018 – the date on which the General Data Protection Regulation (hereinafter GDPR) would come into effect.

The aforementioned inspection was conducted, with prior notification to the data controller, at its facilities located at 115 Metsovou Street in Athens, following the Protocol No. G/EX/7873/14-11-2019 order of the President of the Authority. The inspection was scheduled to ascertain the compliance of the data controller with the requirements described in the aforementioned Opinions of the Authority, in light of both the General Data Protection Regulation and the following additional elements which initially raised questions regarding whether the anonymity of movements is ensured (an issue that has been raised in the aforementioned Opinions of the Authority):

i) Relevant publications, during the period of the inspection, reported that "there have been recorded cases of citizens who declare unemployed and who daily make the same route, at the exact same times, using public transport."¹

¹ See, for example,

<https://www.iefimerida.gr/ellada/xekina-safari-gia-anergoys-maimoy-se-sygkoinonies> (last accessed on: 16/6/2023)

3

ii) The manner in which OASA conducts the control during the renewal process of a personalized electronic ticket of a special category by its holder through a terminal was not clear, regarding whether

the ticket holder still falls under the specific special category (given that OASA does not maintain records of names, nor does it correlate the number of the electronic ticket with the AMKA of its holder). In the context of the control, the Data Protection Impact Assessment (DPIA) referred to in the above Opinion 4/2017 of the Authority was also requested. Furthermore, the audit team requested information on the processing through the ASSK, and also requested a set of documents as evidence, which the data controller subsequently submitted to the Authority. Since the preparation of the DPIA had not been completed at the time of the on-site audit, the data controller informed that it would be sent to the Authority upon its completion. The DPIA was later submitted with document number G/EIS/9092/30-12-2019, while a few days earlier, the data controller submitted to the Authority additional supplementary documents, following the requests made by the audit team.

Subsequently, the audit team drafted the Minutes of the audit (hereinafter referred to as the Minutes), which record the responses/clarifications of the audited entity, as well as on-site observations of the audit team. The Minutes were sent to the data controller via email on 01-06-2020 for comments and/or observations. The data controller responded with document number G/EIS/4340/23-06-2020, providing additional files.

Thereafter, the said Minutes were finalized with document number G/EX/7971/19-11-2020. The Minutes include a detailed description of all the evidence submitted.

Following this, the audit team studied the Minutes in conjunction with the evidence collected and submitted to the Authority the audit report with document number G/EIS/8221/30-11-2020. The Report is accompanied by an annex containing the audit minutes, which annex is an integral part of the Report.

The main findings of the audit, as analyzed in the report, are as follows:

Finding 1 - Untimely preparation of DPIA: The impact assessment regarding the protection of personal data was not available at the time of the audit, but was eventually submitted to the Authority later, as previously mentioned, on 30-12-2019.

Finding 2 - Insufficient content of the impact assessment regarding the protection of personal data: As analyzed in the audit report, the DPIA, which was submitted after the audit, presents ambiguities in many points, does not examine all the risks regarding the protection of personal data, and the risks that are examined do not appear to be assessed appropriately. Additionally, a discrepancy was found between the impact assessment and the activity record considered by the Authority regarding the legal bases for processing for various purposes, which is not documented.

Finding 3 - Data retention period: The data retention period within the framework of the ASSK had not been determined at the time of the audit. After the audit, a retention period of 20 years was chosen for all purposes of the system, without distinction and without relevant documentation.

Finding 4 - Activity record of processing: The purposes of the said processing are not described in the activity record as thoroughly as the data controller initially described them to the Authority and as they are described in Opinions 1/2017 and 4/2017 of the Authority. Furthermore, there is no correspondence between the purposes described in the activity record and the relevant information provided to data subjects at that time through OASA's website.

Subsequently, the Authority summoned OASA to a hearing in a session, via videoconference, of the Plenary on 10-12-2020 (see call with document number G/EX/8295/2-12-2020), which was however postponed. With a subsequent call (see call with document number G/EXE/279/04-02-2022), OASA was summoned to a session of the Authority's Plenary, via videoconference, on 15-02-2022. In the session on 15-02-2022, the following individuals were present: A, Data Protection Officer of OASA, B, representative for the ASSK, C, OASA consultant on personal data issues, D, OASA consultant on personal data issues, Athanasios Mitroussis, lawyer for OASA, and E, Data Protection Officer of the contracting company HST. After the session, OASA was given a deadline to submit a memorandum, for which it subsequently requested, with document number G/EIS/3925/10-03-2022, a few days' extension, due to the fact that specifically for the...

5

In the operation of the ASSK, OASA approached the contractor of the project, the company "HELLAS SMARTICKET S.A.", which undertook to prepare a technical report based on the observations of the Authority expressed during the aforementioned meeting; however, it was not possible to complete the

relevant report in a timely manner. Subsequently, OASA submitted, within the new deadline set, the memorandum numbered G/EIS/4920/22-03-2022, as supplemented by the document numbered G/EIS/5320/28-03-2022, which was submitted three (3) days after the expiration of the new deadline and includes the new DPIA, the new processing activities record of OASA, as well as the aforementioned technical report from the contracting company.

In the above memorandum, along with its supplementary documents, the following is stated regarding the aforementioned findings of the audit:

1) Regarding the untimely preparation of the DPIA, OASA states that, following the Authority's Opinion 4/2017, it approached the contractor of the project "HELLAS SMART TICKET S.A." (hereinafter, HST) for the organization of the aforementioned study, and that, during that specific period, experience regarding the preparation of impact assessments was limited. On 3/5/2018, the said study was assigned to the Laboratory of Legal Informatics of the Law School of the University of Athens (hereinafter ENP). With this assignment, it became clear that there were difficulties stemming from the fact that time was required for ENP to understand the processing activities of the ASSK and, consequently, the related compliance requirements with the legislation, that there were no standards or methodologies for the preparation of DPIAs at that time, as well as that difficulties arose in effectively obtaining information from OASA's contractors and subcontractors.

2) Regarding the issues related to the content of the DPIA, which was ultimately submitted, as mentioned above, on 30/12/2019, OASA states that the said study has since been updated. Changes occurred: i) on 10/6/2020, following the receipt of the audit report by OASA, ii) on 10/2/2022, in view of the hearing process before the Authority, and iii) on 15/03/2022, following this and after communications with HST for its submission of a technical report regarding the elimination - through the implemented technical fragmentation and the related security measures - of the possibility of identifying the holders of the personalized "ATHENA CARD" cards. OASA states that it has taken into account, for the preparation of the DPIA, the Guidelines of the Article 29 Working Party, the relevant Guidelines of the French Data Protection Authority (CNIL), the relevant Guidelines of the British Information Commissioner's Office (ICO), the proposed Methodologies of the European Union Agency for Cybersecurity (ENISA), the Opinions 1/2017 and 4/2017 of the Authority, as well as the Decision No. 65/2018 of the Authority. For the individual issues regarding the DPIA raised in the audit report, OASA refers, in its memorandum, to specific sections within the new edition of the DPIA.

3) Regarding the data retention period for data processed within the framework of the ASSK, OASA states in its memorandum that the record of activities has been updated, specifically stating, for each of the purposes of processing served by the ASSK, the retention periods for the data processed in light of these purposes. Furthermore, in the updated DPIA, an attempt is made to document the necessity and proportionality of retaining the data for the specified time periods. Specifically, in relation to the twenty-year period as the maximum retention period for the data, the following is noted: "Specifically, the data ((re)charging, validation, and consequently, fare control, has been decided to be retained for 20 years for the purpose of ensuring OASA's compliance with the provisions of tax legislation. Specifically, in view of the twenty-year limitation period provided for cases of tax evasion (Article 36, paragraph 3 of Law 4174/2013) - and despite the fact that this does not initially affect the retention period of books and records for tax years from 2014 onwards - OASA deemed it appropriate to retain the specific data for twenty years from their collection. To this end, particular consideration was given to the fact that the functions under examination ((re)charging and validation) do not require identification with a natural person (the holder of the personalized card). The identification of passengers during fare control is carried out solely by the (physical) presentation of the personalized card's component." In this regard, it is also mentioned in the updated DPIA submitted after the hearing.

7

of the data controller to the Authority, "a user may request an analysis of their movement history - their transactions. For example, if a passenger complains about an excessive charge when validating their card at a station or vehicle, checking the movement history is necessary to confirm or deny the passenger's claims and ultimately resolve the issue. Moreover, the user may consider themselves entitled to dispute any zero balance on their card or any charge-transaction, which is, in any case, also interesting from a tax perspective."

4) The content of the processing activities record was initially determined based on the provisions of the OASA Service Organization (Government Gazette PRA.DI.T. 148/22-3-2019). Following the receipt of the audit report by the Organization, the processing activities record was updated so that the purposes of processing were described as thoroughly as OASA had initially described them to the Authority. Furthermore, the content of the information provided to data subjects through the official website of OASA was updated. Specifically, the purposes of processing described in the processing activities record were grouped according to the content of Opinion 1/2017 and reflected in the text of the Information as follows: "a. Avoidance of boarding a means of transport without payment of the required fare. b. Provision of new services to the traveling public such as i) issuance of a new card – in case of loss for any reason – with the transfer of the remaining prepaid amount to the new card, ii) reissuance of a card, iii) online recharging of the product through the customer service website. c. Facilitation of the violation control and fine imposition process. d. Provision of the ability for OASA to extract statistical information that will allow it to improve the services it provides - as described in the history of this document. e. Provision of the ability for OASA to know precisely the number of movements for those categories of passengers for whom Public Entities, under whose supervision the said beneficiaries fall, are obliged to reimburse OASA for the transport work provided." Furthermore, the aforementioned information was updated regarding the retention periods of the data mentioned therein. The updated information was scheduled, as stated in OASA's memorandum, to be posted on OASA's official website by the end of March 2022.

5) Furthermore, OASA, in its memorandum, regarding whether the data retained in the ASSK is anonymous, refers to Opinion 05/2014 of the Article 29 Working Party, which states that anonymized data is data that has been transformed in such a way that the identity of the person to whom it relates cannot be ascertained by "all" "possible" and reasonable "means." In the same Opinion, reference is made to hashing functions, which are standardized as "techniques for pseudonymization." Among these functions, there is also one based on a secret key. In this case, OASA, during the operation of the ASSK, uses a hashing function based on an eight-digit "PIN" number (composed of eight numerical digits), which is freely chosen by each holder of a personalized card and remains secret. OASA states that, as noted by the Article 29 Working Party, although the Data Controller can "reproduce the function in the same characteristic using the secret key, (...), reproduction is far more difficult for a potential intruder if they do not know the key, as the number of possible values that must be tested is sufficiently large to make testing them practically impossible." In light of the security measures implemented, which are described in detail in Section 3.6 of the updated DPIA, OASA believes that it should be accepted that the identification of the holders of personalized cards becomes nearly impossible in any case, especially for third-party "intruders" - also referring to Section 5.1 of the updated DPIA.

The Authority, in its meeting on 12/4/2022, concluded that OASA had not fully substantiated in its memorandum – although it had been requested – the need to retain movement data for twenty (20) years, and therefore requested more information in a subsequent document. Specifically, in its letter No. G/EXE/1178/18-05-2022, the Authority requested OASA to clarify the following:

a) How the retention of recharging, validation, and

9

control of fare with tax evasion and generally with the provisions of tax legislation? (see updated EAPD, p. 29).

b) Why was a retention period of twenty years chosen for the aforementioned data, while the specific provision (art. 36 par. 3 Law 4174/2013) provides for a ten-year deadline for the issuance of a tax administrative determination?

In the same document, the Authority emphasized that in any case, the reason for invoking the provision of Article 36 par. 3 of Law 4174/2013 must be documented in detail, as well as the choice regarding the retention of the data for twenty years.

Furthermore, in the same document, the Authority requested, in addition to the above - related to tax legislation - issues, clarification on whether the possibility of anonymizing the data of reloading, validation, and fare control (i.e., deletion of the unique card number, while retaining other information such as beneficiary category, validation points and times, etc.), shortly after their creation, adversely

affects the other processing purposes – and in the affirmative case, to provide documentation regarding this.

OASA did not respond to the said document, apart from an electronic message from the Data Protection Officer of OASA sent on 30-8-2022 (ref. no.: G/EIS/3066/30-8-2022) which stated, among other things, that there would be a response within 10 days.

The Authority, after examining all the elements of the file and the discussions that took place in the meeting of 15-02-2022, having heard the rapporteur and the clarifications of the assistant rapporteurs, and after thorough discussion,

CONSIDERED IN ACCORDANCE WITH THE LAW

1. According to the provisions of Articles 51 and 55 of the General Data Protection Regulation (EU) 2016/679 (hereinafter, GDPR) and Article 9 of Law 4624/2019 (Government Gazette A' 137), the Authority has the competence to supervise the application of the provisions of the GDPR, this law, and other regulations concerning the protection of individuals from the processing of personal data.

2. According to Article 4, point 1 of the GDPR, "personal data" means any information relating to an identified or identifiable natural person ("data subject"), whereas an identifiable natural person is one whose identity can be ascertained, directly or indirectly, in particular by reference to an identifier such as a name, identification number, location data, online identifier, or one or more factors specific to the physical, physiological, genetic, psychological, economic, cultural, or social identity of that natural person.

3. "Pseudonymization" is defined, according to Article 4, point 5 of the GDPR, as the processing of personal data in such a way that the data can no longer be attributed to a specific data subject without the use of additional information, provided that such additional information is kept separately and is subject to technical and organizational measures to ensure that it cannot be attributed to an identified or identifiable natural person.

In this regard, Recital 26 of the GDPR states that "personal data that have been pseudonymized, which could be attributed to a natural person by the use of supplementary information, should be considered information relating to an identifiable natural person. In order to determine whether a natural person is identifiable, all means that could reasonably be used, such as the separation of the data from the data controller or a third party for the direct or indirect identification of the natural person, should be taken into account. To ascertain whether any means are reasonably likely to be used to identify the natural person, all objective factors should be considered, such as the costs and time required for identification, taking into account the technology available at the time of processing and technological developments."

4. Furthermore, according to Article 4, point 7 of the GDPR, the data controller is defined as "the natural or legal person, public authority, agency, or other body that, alone or jointly with others, determines the purposes and means of the processing of personal data."

11

"alone or jointly with others, determine the purposes and means of processing personal data."

5. According to Article 5(1) of the General Data Protection Regulation, personal data:

a) shall be processed lawfully and fairly in a transparent manner in relation to the data subject ("lawfulness, fairness, and transparency"),

b) are collected for specified, explicit, and legitimate purposes and shall not be further processed in a manner incompatible with those purposes ("purpose limitation"),

c) are adequate, relevant, and limited to what is necessary for the purposes for which they are processed ("data minimization"),

d) are accurate and, where necessary, kept up to date; all reasonable steps must be taken to ensure that personal data that are inaccurate, with respect to the purposes of processing, are erased or rectified without delay ("accuracy"),

e) are kept in a form which permits identification of data subjects for no longer than is necessary for the purposes of processing personal data; personal data may be stored for longer periods, provided that the personal data will be processed solely for archiving purposes in the public interest, for scientific or

historical research purposes, or for statistical purposes, in accordance with Article 89(1) of the GDPR and provided that appropriate technical and organizational measures are applied to safeguard the rights and freedoms of the data subject ("storage limitation"),

f) shall be processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, using appropriate technical or organizational measures ("integrity and confidentiality").

6. Furthermore, according to paragraph 2 of the same article, "the controller shall be responsible for, and be able to demonstrate compliance with, paragraph 1 ("accountability")." The introduction of the principle of accountability shifts the "burden of proof" regarding the lawfulness of processing and compliance with the GDPR from the data protection authorities to the controllers or processors themselves. The GDPR provides controllers/processors with a range of regulatory methods and tools for this purpose, such as -among others- maintaining records of processing activities, implementing security measures, and conducting data protection impact assessments.

7. Moreover, for the processing of personal data to be lawful, it must have a legal basis as described in Article 6 of the GDPR. According to the provision of Article 6(1), "processing shall be lawful only if and to the extent that at least one of the following applies (...) f) processing is necessary for the purposes of the legitimate interests pursued by the controller or by a third party, except where such interests are overridden by the interests or fundamental rights and freedoms of the data subject which require protection of personal data, especially if the data subject is a child." However, as defined in the next paragraph of the same provision, this legal basis does not apply to processing carried out by public authorities in the performance of their tasks. As clarified in Recital 47 of the GDPR, the justification for the prohibition of applying this legal basis to processing carried out by public authorities in the performance of their duties lies in the principle of legality, meaning that, with respect to public authorities, it is up to the legislator to provide by law the legal basis for the processing they undertake.

8. Article 4 of Law 4624/2019 provides that "public authority" means public authorities, independent and regulatory administrative authorities, legal entities under public law, local government authorities of the first and second degree, and their legal entities and enterprises, state or public enterprises and organizations, legal entities under private law that are owned by the state or are subsidized by at least 50% of their annual budget or whose management is appointed by it."

13

9. O OASA is, according to its founding law 2175/1993, a legal entity of private law and specifically a public enterprise of a charitable nature in the form of a public limited company; it is supervised by the Minister of Transport and Communications, and its share capital belongs to the State (see law 2175/1993, articles 1, 2), while the chairman and the managing director are appointed by a joint decision of the Minister of National Economy, Finance, and the Minister of Transport and Communications (see law 2175/1993, article 2, paragraph 3).

10. The GDPR does not define what constitutes a "public authority or public body." The Article 29 Working Party in its Guidelines on Data Protection Officers (WP 243), which have been adopted by the European Data Protection Board, considers that this concept should be defined by national laws, but believes that the fulfillment of a public duty and the exercise of public authority can occur not only by public authorities or public bodies but also by other natural or legal persons of public or private law, in various sectors arising from the national legislation of each Member State, such as public transport services, water supply and energy provision, road infrastructure, public broadcasting, the construction of workers' housing, or disciplinary bodies for legislatively protected professions. In these cases, data subjects are likely to find themselves in a situation very similar to the processing of their data by a public authority or public body. Specifically, data processing for similar purposes is possible, and likewise, individuals usually have little or no choice regarding whether and how their data will be processed. This view of the Article 29 Working Party reflects the prevailing perspective of Greek theory and case law, according to which public enterprises providing vital services for the social whole, regardless of their form as legal entities of private law, pursue the public purpose of ensuring for the social whole those vital goods and services without which the normal conditions for a decent human living according to modern criteria and the free development of personality and activity guaranteed by the Constitution cannot exist. In order to ensure the safeguarding of the constitutional guarantees

surrounding the vital services provided (e.g., public transport, water supply, sewage, etc.), the State, through the regulatory supervision and ownership control it exercises over public enterprises, participating with a majority in their share capital, uses tools of administrative law that essentially constitute the exercise of public authority.

11. Regarding the principle of transparency of processing, the GDPR imposes specific obligations on data controllers concerning the information they must provide to data subjects. Specifically, according to Article 12 paragraph 1 of the GDPR, the data controller takes appropriate measures to provide the data subject with all information referred to in Article 13 – which specifically states that "when personal data relating to a data subject are collected from the data subject, the data controller, at the time of collecting the personal data, provides the data subject with all of the following information: a) the identity and contact details of the data controller and, where applicable, of the representative of the data controller, b) the contact details of the data protection officer, where applicable, c) the purposes of the processing for which the personal data are intended, as well as the legal basis for the processing, d) if the processing is based on Article 6 paragraph 1 point f), the legitimate interests pursued by the data controller or by a third party, e) the recipients or categories of recipients of the personal data, if any (...)" (see paragraph 1 of Article 13 of the GDPR). Furthermore, in paragraph 2 of the same article, it is provided that "in addition to the information referred to in paragraph 1, the data controller, at the time of collecting the data...".

15. Personal data provides the data subject with the following additional information necessary to ensure fair and transparent processing: a) the period for which the personal data will be stored or, when that is not possible, the criteria used to determine that period (...).

12. Article 25(1) of the GDPR establishes the principle of data protection by design as follows: "Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons posed by the processing, the data controller implements effective, both at the time of determining the means of processing and at the time of processing, appropriate technical and organizational measures, such as pseudonymization, designed to implement the data protection principles, such as data minimization, and to integrate the necessary safeguards into the processing in such a way that the requirements of this Regulation are met and the rights of data subjects are protected." Specifically regarding the security of processing, Article 32(1) of the GDPR states that "taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons, the data controller and the processor implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, including, among others, as appropriate: a) the pseudonymization and encryption of personal data (...)."

13. Regarding the data protection impact assessment, Article 35 of the GDPR states that when a type of processing, particularly using new technologies and taking into account the nature, scope, context, and purposes of the processing, is likely to result in a high risk to the rights and freedoms of natural persons, the data controller shall carry out, prior to the processing, an assessment of the impact of the intended processing operations on the protection of personal data. Furthermore, the DPIA is a key tool for fulfilling the principle of data protection by design, as outlined in Article 25(1) of the GDPR (see Decision 50/2021 of the Authority).

14. The Authority has established, based on Article 35(4) of the GDPR, a list of types of processing operations that are subject to the requirement for conducting a DPIA (see Decision 65/2018 of the Authority). According to this list, a data protection impact assessment is required in cases, among others, of "systematic and large-scale processing for the monitoring, observation, or control of natural persons using data collected through video surveillance systems or through networks or by any other means in public spaces, publicly accessible spaces, or private spaces accessible to an unlimited number of persons. This includes monitoring the movements or location/geographical position in real-time or non-real-time of identified or identifiable natural persons. Relevant examples include the use of cameras in a shopping mall or at public transport stations, or the processing of location data of

passengers at an airport or on public transport."

15. In this specific case, regarding the processing of data through the ASSK, OASA is the data controller within the meaning of Article 4(7) of the GDPR. It is noted that, for personalized tickets, the data processing carried out by the ASSK concerning the movements of the passenger public constitutes the processing of personal and not anonymous data, even though the names of passengers are not retained. This is because the database of the ASSK stores the "digital fingerprint" ("hashed value") resulting from the combination of the passenger's AMKA (or passport number or other official identification document) and the 8-digit code (PIN), as well as the month and year of birth and the specific category of the beneficiary. Therefore, the AMKA and the 8-digit code chosen by each user are the pieces of information that allow for the matching of the AMKA with the digital fingerprint – and thus, the identification (via the AMKA) of the passenger holding a card with a specific digital fingerprint.

6 Although the fingerprint cannot yield the AMKA or the code, it is still possible to easily verify whether a known AMKA and code correspond to the specific digital fingerprint.

17

number, which consequently allows for the identification of his movements. OASA correctly does not maintain this information (see also Opinions 1/2017 and 4/2017 of the Authority), in application of the principle of data minimization, according to Article 5(1)(c) of the GDPR, as well as within the framework of its obligations for data protection by design (Article 25 of the GDPR) and for secure processing (Article 32 of the GDPR). This information is only in the possession of each data subject (cardholder) in order to prove, whenever they wish (especially in case of loss of their card), that they indeed held a card with a specific number. However, this does not render the data anonymous, but rather pseudonymous, since there are ultimately supplementary information (in the possession of the data subject themselves) that allows for their attribution to a specific natural person. Furthermore, as analyzed below, considering the means that the data controller can reasonably use, the possibility of re-identification cannot be excluded – while, moreover, the fact that OASA, for the reasons it invokes and which have already been mentioned above, retains movement data for twenty (20) years demonstrates that such data cannot be characterized as anonymous.

16. Regarding the implementation of the DPIA, OASA cites, among other reasons for the delay in its preparation, the difficulty of gathering information about the system from the contractors. However, the above claims, as presented, do not constitute a justification for this delay. It is noted that according to Article 28 of the GDPR, "processing by a processor shall be governed by a contract or other legal act under Union or Member State law, which binds the processor to the controller and sets out the subject matter and duration of the processing, the nature and purpose of the processing, the type of personal data and categories of data subjects, and the obligations and rights of the controller. The said contract or other legal act specifically provides that the processor: (...) (e) assists the controller in ensuring compliance with the obligations arising from Articles 32 to 36, taking into account the nature of the processing and the information available to the processor (...)". Therefore, the data controller should have taken appropriate measures to ensure the timely preparation of the impact assessment regarding personal data, as well as the implementation of any corrective measures that the results of the study might indicate, without this obligation being lifted due to difficulties arising from the collection of data from the processors.

17. Regarding the content of the updated DPIA, which was submitted after the hearing of the data controller before the Authority, although it is indeed improved compared to its initial version (which was submitted after the on-site inspection of the Authority), the following observations are made: The new DPIA states that it is based on the relevant methodology of CNIL⁷ (with a general reference to the CNIL website). However, there does not appear to be complete agreement with the steps described in relevant CNIL manuals available on its website. This alone does not constitute an incomplete preparation of the DPIA, as there is no obligation for the data controller to adopt any specific methodology; however, there are still some unclear points or even omissions regarding the approach ultimately followed for the risk assessment. These points can be summarized as follows:

a. Unclear documentation of the method of calculating each risk, which is a deficiency directly related

to the unclear documentation of the determination of both the likelihood of occurrence of each risk and the related consequences of its occurrence (more detailed documentation is provided in the confidential annex of this document).

b. As a direct consequence of the above, it appears that, although measures are indeed taken to address various risks that are in the right direction, there is still room for additional measures, particularly regarding the risk of unauthorized matching of a passenger's movements with their AMKA (more detailed documentation is provided in the confidential annex of this document). Therefore, there is a de facto issue of non-compliance with the principle of data protection by design.

7 This refers to the supervisory authority for data protection in France.

19. Design, based on Article 25 of the GDPR.

c. It does not appear that a proper assessment of the legal basis for the various processing purposes has been made within the EAPD (this is further analyzed below in Recital 19).

d. The EAPD does not address issues related to the transparency of processing as well as the other rights of data subjects. More generally, the EAPD primarily focuses on issues of processing security rather than on other data protection risks (e.g., it does not examine whether contracts with data processors address various risks, etc., while it does not provide sufficient documentation regarding the issue of data retention periods, as described below in Recital 18).

18. Regarding the data retention periods for the various processing purposes, OASA, which had not specified data retention periods at the time of the on-site inspection and, after the inspection, set a retention period of 20 years for all data, regardless of the processing purposes, has now proceeded to specify the retention periods for the various data processing purposes—without the twenty-year period applying universally to all purposes. However, ultimately, it appears that movement data continues to be retained for twenty years, on the grounds that their retention is justified for tax purposes, “given—as OASA states in its memorandum—the twenty-year statute of limitations provided for cases of tax evasion (Article 36, paragraph 3 of Law 4174/2013).” The examples mentioned do not relate to the tax obligations of the Organization but to requests that data subjects may submit. Specifically, as noted in the updated EAPD, “a user is likely to request an analysis of their movement history—of their transactions. For example, if a passenger complains about an excessive charge when validating their card at a station or vehicle, checking the movement history is necessary to confirm or deny the passenger's claims and ultimately resolve the issue. Moreover, the user may consider that they are entitled to dispute any zero balance on their card or any charge-transaction, which is, in any case, interesting from a tax perspective.” As noted in the background of this document, OASA did not respond to a more recent document from the Authority to provide further clarifications on this matter, explaining, among other things, why the twenty-year retention period was chosen for the aforementioned data by invoking a twenty-year statute of limitations in cases of tax evasion without citing a specific provision, while the provision of Article 36, paragraph 3 of Law 4174/2013, according to which it was possible to issue a tax determination act in cases of tax evasion within twenty years and which OASA invoked, has been replaced by Article 32, paragraph 2 of Law 4646/2019, which sets the deadline for issuing the tax determination act at ten years.

19. OASA, for various processing purposes, cites as the legal basis for processing the provision of Article 6, paragraph 1, point (f) (this applies both in the updated EAPD and in the updated processing activities record submitted to the Authority following the findings of the Authority's audit report that was communicated to it). However, for the reasons outlined above, this legal basis cannot be used by OASA, which is a public utility enterprise, supervised and controlled in ownership by the state. Moreover, OASA's invocation for certain processing purposes of the provision of Article 6, paragraph 1, point (e) (processing necessary for the performance of a task carried out in the public interest or in the exercise of official authority vested in the controller) reinforces the view that OASA, as a public utility enterprise, falls within the concept of “public authorities,” as defined in the last sentence of Article 6, paragraph 1, in addition to the contradiction that arises from the simultaneous invocation of Article 6, paragraph 1, point (f) as a legal basis.

Furthermore, it should be noted that the recognition and selection of the appropriate legal basis from those provided in Article 6, paragraph 1 of the GDPR is closely linked to the principle of lawful or fair

processing as well as to the principle of purpose limitation, and the data controller is obliged not only to select the appropriate legal basis prior to the commencement of processing but also to inform, pursuant to Article 13, paragraph 1, point (c) and Article 14, paragraph 1, point (c) of the GDPR, the data subject about its use, as the choice of each legal basis has a legal impact on the application of the

21

Rights of the Data Subjects.⁸

Furthermore, the expression of the principle of legality of processing is also the principle of transparency.⁹ Pursuant to Article 5(1)(a) of the GDPR, in addition to the requirement that data be processed lawfully and fairly, transparency is expressly included as a fundamental aspect of these principles, and is inherently linked both to legality and to the principle of accountability, according to which the data controller must always be able to demonstrate that personal data is processed transparently in relation to the data subjects.¹⁰

In this context, while it cannot be excluded that in specific cases the possibility of simultaneous application of different legal bases for the processing of personal data may arise, this is only permissible if they are used in the correct context and particularly if they serve different processing purposes. For the same processing purpose, the data controller must initially choose a specific legal basis, the most appropriate in relation to the specific purpose. In this way, the data subjects know precisely, without any doubt, the correct legal basis for each processing operation, while the data controller, in this regard, complies with the principle of accountability under Article 5(2) of the GDPR, since, according to this provision, as previously mentioned, they bear the burden of invoking and proving the legality of the processing, which does not arise when two different legal bases are presented simultaneously for the same processing purpose.

20. Regarding the information provided to data subjects about the purposes of processing, the website of OASA has been updated in accordance with what the organization states in its memorandum (last access to the OASA website: 9/6/2023). However, for the following purposes of processing: a) to enable the study of anonymized statistical data by OASA and third parties, in such a way that they cannot identify the data subject, b) to enable the management of websites and all forms of communication, reference is made, regarding the legal bases for processing, to three legal bases, thereby preventing the easy identification of the correct one for each purpose, according to what is stated above in Recital 19 - while one of the legal bases is the legitimate interest of OASA, which, as previously mentioned, cannot apply in this specific case.

21. In conclusion, the Authority finds the following violations for OASA:

- a. Violation of Article 5(1)(e) of the GDPR regarding the principle of storage limitation (see above Recital 18 of this document, as well as Finding 3 of the audit report).
- b. Violation of Article 35(1) of the GDPR regarding the preparation of a Data Protection Impact Assessment (DPIA), as it had not been prepared in a timely manner (it was not available at the time of the on-site audit - see Finding 1 of the audit report), and even after its preparation, as well as after various revisions, it appears that it has not been prepared in such a way as to fully document the handling of all data protection risks (see above Recital 17). Furthermore, in the updated DPIA, there is problematic presentation of the legal bases (see Recital 17, point c).
- c. Violation of Article 25(1) of the GDPR regarding data protection by design, since, although measures have indeed been taken by design to address various risks, it appears that there is room for additional measures, for which the necessity of their implementation is not documented (see above Recital 17, point b of this).
- d. Violation of Article 30(1) of the GDPR regarding the proper maintenance of the records of processing activities, as it was not properly completed (there was ambiguity in the description of the purposes of processing, as described in Finding 4 of the audit report).

The above violation under point d has been remedied by the data controller, as evidenced by the memorandum with the accompanying documents submitted to the Authority after their hearing before the Authority. However, in the

23. An updated activity file is provided - although there is no relevant obligation under the provisions of Article 30 of the GDPR - the corresponding legal bases for the various purposes of processing, for

which ambiguity arises according to what is described above in Recital 19, in violation of Article 6(1) of the GDPR, as well as in the information provided to data subjects through the organization's website (see Recital 20). Therefore, the Authority emphasizes that OASA must take appropriate actions to ensure it is absolutely clear what the correct legal basis is for each purpose of processing carried out through the ASSK, and this must also be provided as information to the data subjects.

22. Based on the above, the Authority considers that there is a case to exercise its corrective powers under Article 58(2) of the GDPR in relation to the identified violations.

23. The Authority further considers that, based on the circumstances identified, an effective, proportionate, and deterrent administrative monetary fine must be imposed in accordance with the provision of Article 58(2)(h) of the GDPR, pursuant to Article 83 of the GDPR.

24. Furthermore, the Authority took into account the criteria for assessing the fine as defined in Article 83(2) of the GDPR, the paragraphs 4 and 5 of the same article applicable to the present case, Article 39(1) and (2) of Law 4624/2019 concerning the imposition of administrative sanctions on public sector entities, and the Guidelines 4/2022 of the European Data Protection Board for calculating administrative fines for the purposes of Regulation 2016/679, which were approved on 24/5/2023, as well as the factual data of the case under examination and particularly the following:

i) The identified violation of Article 5(1) of the GDPR falls, according to the provisions of Article 83(5)(b) of the GDPR, within the highest category of the administrative fine grading system ("significant" violations with a maximum amount of €20,000,000).

11 See https://edpb.europa.eu/system/files/2023-06/edpb_guidelines_042022_calculationofadministrativefines_en.pdf (last accessed: 16/6/2023)

24. ii) The activity of the data controller has a wide scope, as it concerns the entire passenger public of public transport in Athens,

iii) The activity relates to the main activities of the data controller.

iv) The processing mainly concerns "simple" personal data, but also involves special categories of data, such as those related to the movements of persons with disabilities.

v) The data controller demonstrated difficulty in cooperating with the Authority regarding the documentation of the data retention period (violation of Article 5(1)(e)), failing to provide the requested information.

vi) No material harm to the data subjects is evident.

vii) OASA took some corrective actions after the on-site inspection, regarding the determination of the data retention period (since prior to the on-site inspection, the retention periods for the various purposes of processing had not been determined at all).

viii) The most recent available online data regarding the financial revenues and turnover of the data controller for 2021.

25. The Authority considers that, based on the circumstances identified, the sanctions mentioned in the operative part of the decision are the effective, proportionate, and deterrent measure both for restoring compliance and for punishing the unlawful behavior.

12 Available at the link <https://oasa.b-cdn.net/wp-content/uploads/2022/10/MONOΣΕΛΙΔΟ-ΟΑΣΑ-31-12-2021-ΔΣ-ΤΕΛΙΚΟ.pdf> (last accessed: 16/6/2023)

25

FOR THESE REASONS

The Authority, taking into account the above:

a) Imposes, based on Article 58 paragraph 2 subparagraph (h) of the GDPR, a fine on the "Urban Transport Organization S.A." in the total amount of 50,000 euros, for the violation of Article 5 paragraph 2 subparagraph (e) of Regulation (EU) 2016/679.

b) Issues, based on Article 58 paragraph 2 subparagraph (b) of Regulation (EU) 2016/679, a reprimand to the "Urban Transport Organization S.A." for the violations of the provisions of Article 25 paragraph 1 and Article 35 paragraph 1 of Regulation (EU) 2016/679.

c) Orders compliance to the "Urban Transport Organization S.A.", in accordance with Article 58 paragraph 2 subparagraph (d) of the GDPR, in order to determine and document, within one (1) month, all data retention periods for the various processing purposes of the UTO. In the event that, after this determination of the retention period, it is found that personal data is already being retained beyond this period, then it must promptly either delete or anonymize this data, documenting accordingly and also informing the Authority. The relevant information regarding the data retention periods for the various processing purposes must also be provided to the data subjects. In any case, for the determination of the data retention period, the UTO must examine whether the possibility of anonymizing the data related to recharging, validation, and fare control (i.e., deleting the unique card number while retaining other information such as beneficiary category, validation points and times, etc.) shortly after their creation adversely affects the other processing purposes, with appropriate documentation in the affirmative case.

d) Orders compliance to the "Urban Transport Organization S.A.", in accordance with Article 58 paragraph 2 subparagraph (d) of the GDPR, in order, within three (3) months, to revise the impact assessment regarding personal data according to what is stated herein, as well as to implement any additional measures deemed necessary to address the various risks, taking into account what is stated in Recital 17 of this document.

The President

The Secretary

Konstantinos Menoudakos

Irini Papageorgopoulou